

Blacktech Network Security Plan

v1.0

Derrell A Black, CEO

September 22, 2026

BLACKTECH SOLUTIONS CORP

Network & Infrastructure Security Plan

v1.0

Prepared: September 22, 2026 **Owner:** Derrell A Black, CEO **Scope:** Home rack — Raspberry Pi (brain) + node2 + node3 + node4 + Command Center **Framework basis:** NIST Cybersecurity Framework 2.0 · CIS Controls v8.1 (IG1)

EXECUTIVE SUMMARY

Blacktech runs its own infrastructure: a 4-machine rack on a private Tailscale network, about 30 self-hosted services, and 52 public hostnames routed through Cloudflare Tunnel. This is a real business platform carrying real customer data — names, phone numbers, addresses, credit information, payroll, invoices, and crypto/trust documents.

Current grade: B– — the architecture is sound (nothing is directly exposed, default-deny firewall, private admin network) but three hygiene items leave the front door unlocked, and we just spent the day closing 17 live data leaks that existed precisely because there was no written standard to check the work against.

This document is that standard. It names the 3 things to fix now, then lays out a 5-phase plan mapped to CIS IG1 so the rack gets stronger every quarter instead of only when something breaks.

1. HOW THE NETWORK STAYS PRIVATE

(the core design)

The single most important security decision in this network is already made, and it is this: **nothing on the rack is exposed directly to the internet.**

The model — three layers:

Layer 1 — No open doors (already true). Every service binds to 127.0.0.1 (loopback) or the private LAN. The ONLY way in from the public internet is cloudflared, an outbound-only tunnel. There are no inbound port forwards on the router. An attacker scanning the public internet finds *nothing* — no open ports, no banner, no service. Cloudflare is not a hole in the wall; it is a tunnel that the Pi itself reaches *out* to open.

Layer 2 — Identity at the edge (the big upgrade to make). Today, anyone who knows a hostname (e.g. paybooks.blacktechsolutionscorp.com) reaches a login page. That is one password away from your financials. **Cloudflare Access** (free up to 50 users) inserts an identity check *before* the page even loads — the visitor must authenticate with Google/email and match an allow-list you control, or they see nothing. This turns 52 public hostnames into 52 locked doors where only *you* have the key, while your own devices pass through invisibly.

Layer 3 — Application-level gate (built today). A shared gate (scripts/public_gate.py) now enforces each app's own SSO check on its API routes, distinguishing public traffic (identified by the cf-Connecting-IP header, which only cloudflared sets) from internal loopback traffic. This closed 17 live leaks.

Layer 4 — Private admin path (already true). Tailscale gives you a private, encrypted network across all 4 machines (100.x.x.x). Admin work, SSH, and node management travel this path, never the public internet. **This is why you never need to expose SSH.**

2. CURRENT POSTURE — VERIFIED MEASUREMENTS

Control	Status	Detail
Firewall (UFW)	✓ Good	Active, default deny incoming
Direct internet exposure	✓ Good	No inbound forwards; cloudflared outbound-only
Public hostnames	⚠ Watch	52 routed; API routes now gated

Admin network	✓ Good	Tailscale on all 4 nodes
SSH root login	✓ Good	PermitRootLogin no
SSH password auth	✗ FIX	PasswordAuthentication yes on port 22
Brute-force defense	✗ FIX	fail2ban not installed
Automatic updates	✗ FIX	149 packages pending; unattended-upgrades not installed
Backups	✓ Good	Weekly app backup + daily cloud vault + monthly SD image
Disk encryption	⚠ Accept	SD card unencrypted (physical-access risk only)
Crypto/IPFS ports	✓ Good	5001/4001 denied in UFW
Docker (n8n)	✓ Good	Bound to 127.0.0.1:5678

3. THE THREE THINGS TO FIX NOW (highest risk, lowest effort)

These are the real gaps. Each is a single command block you run yourself.

FIX 1 — Turn off SSH password logins ⚠ HIGHEST PRIORITY

Right now, anyone on the LAN (or the wider internet if a forward is ever added) can brute-force a password on port 22. Keys are already working on all nodes, so passwords are pure liability.

```
sudo sed -i 's/^#\?PasswordAuthentication.*/PasswordAuthentication
no/' /etc/ssh/sshd_config
sudo systemctl restart ssh
```

Before running: confirm key login works from another machine (ssh dblack@node2).

FIX 2 — Install brute-force protection

Blocks an attacker after repeated failed attempts, and bans the IP.

```
sudo apt update && sudo apt install -y fail2ban
sudo systemctl enable --now fail2ban
sudo fail2ban-client status sshd
```

FIX 3 — Turn on automatic security updates

149 packages are pending. Unpatched software is the #1 real-world breach cause — not clever hackers.

```
sudo apt update && sudo apt full-upgrade -y
sudo apt install -y unattended-upgrades
sudo dpkg-reconfigure -plow unattended-upgrades
```

Then reboot to load the kernel/security updates.

Impact of these three: B- → A-.

4. THE FIVE-PHASE PLAN

PHASE 1 — INVENTORY (know what you have) — CIS 1, 2

You cannot protect what you haven't counted. - Every host, service, and port documented in one register - Every piece of software with its version and patch status - Every piece of data classified: Public / Internal / Confidential / Restricted - **Deliverable:** asset & data register, reviewed quarterly

PHASE 2 — CONTROL ACCESS — CIS 5, 6

- Cloudflare Access on all private hostnames (Layer 2 above)
- SSH key-only, no passwords (FIX 1)
- Separate accounts per person — **no shared logins**
- MFA on every business account: email, banking, Cloudflare, Tailscale, socials
- Admin rights only where the job requires it (least privilege)
- Revoke access the same day someone leaves

PHASE 3 — PROTECT DATA — CIS 3, 4

- Encryption in transit (already: HTTPS + Tailscale) and at rest for Restricted data
- Backups follow 3-2-1: three copies, two media, one off-site
- Verify restores — **an untested backup is not a backup**
- Customer PII kept out of public payloads (done today on the

dispatch board)

- Retention & secure disposal rules

PHASE 4 — DETECT & RESPOND — CIS 8, 17

- Central log of who accessed what, and when
- Alerts for: failed logins, new SSH keys, new admin users, outbound data spikes
- Incident response playbook with severity levels and response times
- Weekly review of alerts; monthly review of access lists

PHASE 5 — RECOVER & IMPROVE — CIS 11, 16

- Documented recovery time objective per service
 - Quarterly self-assessment against this plan
 - Annual third-party review
 - Security training for every team member, and a signed acknowledgment
-

5. THE LESSON FROM TODAY (why a written standard matters)

Today's audit found 17 live data leaks — including a publicly readable mailbox with 320 messages and a 1.27 MB customer database. None of them were sophisticated attacks. They were **unauthenticated API routes that quietly bypassed the login page**.

The pattern is worth naming: **the page was protected; the data behind it was not**. Every future service must answer two questions before it goes live:

1. **Is this route public on purpose?** (If you can't say why, it isn't.)
2. **Does the data route enforce the same login as the page?**

A second, subtler lesson: a fix isn't a fix until the *running* service has it. Two services were patched on disk but still running yesterday's code — one had been up since Sep 21 and never loaded the change. **After every security patch: restart, then verify from the public internet, not from inside.**

6. THE STANDING RULES

1. **Default deny.** If a route doesn't need to be public, it isn't.
2. **Nothing binds to the world.** Loopback or Tailscale, always.
3. **Auth at every layer.** Edge (Cloudflare Access) + app (SSO) +

network (Tailscale).

4. **No credential in a browser on a shared machine.** Logins are done by the owner.
5. **Rotate keys on a schedule** (6 months), and immediately on any suspicion.
6. **Verify from outside.** Internal success $\neq$ public closure.
7. **Least privilege.** Every account gets the minimum it needs.
8. **Patch fast.** Security updates within 7 days.

7. 90-DAY SCHEDULE

When	Action	Owner
This week	FIX 1, 2, 3 (SSH, fail2ban, auto-updates + reboot)	Derrell
Week 2	Cloudflare Access on all private hostnames	Derrell + AI
Week 2-3	Verify every service: public 401 / internal 200	AI
Week 3	MFA audit across all business accounts	Derrell
Week 4	Asset & data register (Phase 1)	AI
Month 2	Logging + alerting (Phase 4)	AI
Month 3	Restore drill + quarterly self-assessment	Both

8. ACKNOWLEDGMENT

I have read, understood, and agree to comply with this Network Security Plan.

Name (Print): _____

Signature: _____

Date: _____

Return to: Derrell A Black (CEO) —
support@blacktechsolutionscorp.com

Document control: v1.0 · Issued 2026-09-22 · Next review 2026-12-22
Framework basis: NIST CSF 2.0 (Govern, Identify, Protect, Detect, Respond, Recover) · CIS Critical Security Controls v8.1
Implementation Group 1